

Centro de Ciencias Básicas

Departamento de Sistemas Electrónicos



Benemérita Universidad Autónoma de Aguascalientes

Ingeniería en Sistemas Computacionales

Semestre 8°B

SISTEMA IDS INSTITUCIONAL

Materia: Seguridad en Sistemas

Edgar Alejandro Cedeño Suárez ID: 262728

René Rosendo De Anda Medina ID: 260866

Profesor: Arturo Ocampo Silva

Fecha de entrega: 10/06/2026

1. Marco Teórico y Estructura del Proyecto

1.1 Teoría Principal del Proyecto

El proyecto se fundamenta en la teoría de los **Sistemas de Detección de Intrusos basados en Red (NIDS - Network Intrusion Detection System)**. Un NIDS funciona mediante la inspección de todo el tráfico que fluye a través de un segmento de red, analizando el comportamiento y la información contenida en los paquetes de datos mediante la técnica de *packet sniffing*.

La teoría detrás de este sistema específico integra tres grandes pilares de la ciberseguridad moderna:

1. **Modelo Zero Trust (Confianza Cero) a nivel de Enlace de Datos:** Implementado mediante el uso de listas blancas (*whitelists*) de direcciones MAC e IP. Bajo este paradigma, ningún dispositivo tiene autorización implícita para transitar por la red, previniendo ataques de tipo *Rogue Device* (dispositivos no autorizados).
2. **Inteligencia de Amenazas (Threat Intelligence):** Se nutre de listas negras (*blacklists*) para identificar y calificar conexiones salientes hacia infraestructuras de Comando y Control (C2), servidores de malware o *botnets*.
3. **Respuesta y Análisis Forense Automatizado (SOAR):** No solo detecta, sino que reacciona. Al detectar un incidente, el sistema recopila automáticamente evidencia forense (Whois, ASN, reputación en AbuseIPDB) y notifica al instante, minimizando el tiempo de respuesta del administrador (MTTR - *Mean Time To Respond*).

1.2 Estructura de Componentes y Funcionamiento

La arquitectura del sistema está centralizada en el directorio `ids-backend`, donde reside la lógica principal y el servidor de la aplicación. La interfaz de usuario visual (Frontend) se integra directamente mediante un motor de plantillas dentro del Backend, optimizando la eficiencia y permitiendo un despliegue rápido, por lo que el directorio `ids-frontend` contiene el dashboard web interactivo desarrollado en HTML, CSS y JavaScript vanilla, con dos vistas: Monitor de Red para visualización en tiempo real, y Panel de Control para gestión de listas blancas y negras desde el navegador.

El funcionamiento del sistema se orquesta a través de los siguientes componentes modulares:

- **`main.py` (Orquestador Central):** Punto de inicio del sistema. Carga las configuraciones desde variables de entorno, inicializa las bases de datos en memoria y arranca los procesos principales, incluyendo el motor de captura y los hilos paralelos para la recolección de estadísticas.
- **`sniffer.py` (Motor de Captura):** Utiliza la librería Scapy para interceptar pasivamente los paquetes de red aplicando filtros BPF. Extrae datos de la Capa de Enlace (MAC) y la Capa de Red (IP), enrutando el tráfico interceptado hacia los módulos analíticos de forma asíncrona.

- **whitelist.py (Control de Acceso):** Contrasta cada IP y MAC de origen contra un archivo JSON de dispositivos permitidos. Aplica una lógica anti-spam en memoria para emitir únicamente una advertencia por sesión.
- **dns_monitor.py (Auditoría de Capa 7):** Intercepta el tráfico UDP del puerto 53 para extraer los nombres de dominio solicitados. Registra cada consulta en una base de datos local SQLite (**logs.db**) para la generación de reportes.
- **threat_intel.py (Detección de Amenazas):** Monitorea las IPs de destino contra un catálogo local de firmas maliciosas y activa el protocolo de emergencia al encontrar coincidencias.
- **forensic.py (Analista Automatizado):** Ejecutado tras una detección, consulta bases de datos RDAP y la API de AbuseIPDB para recolectar la jurisdicción, ISP, puntaje de fraude y correo de abuso del atacante.
- **dashboard.py y templates/index.html (Interfaz Visual):** Servidor web ligero en Flask que provee un panel interactivo consumiendo la base de datos SQLite para graficar la actividad en tiempo real.
- **email_alert.py (Notificador):** Construye plantillas HTML dinámicas según el nivel del incidente y despacha alertas automáticas mediante una conexión SMTP segura (TLS)

2. Documentación Segura y Prerrequisitos

2.1 Arquitectura, Módulos y Modelo OSI

El sistema captura tráfico operando en múltiples capas del Modelo OSI a través de 4 módulos funcionales:

- **Módulo de Listas Blancas (Capa 2 y 3):** Extrae la MAC e IP origen. Si el equipo no está registrado, dispara un correo inmediato al administrador.
- **Módulo de Monitoreo (Capa 7):** Inspecciona tráfico HTTP/DNS generando bitácoras en tiempo real de los sitios visitados.
- **Módulo de IPs Peligrosas (Threat Intelligence):** Filtra la capa de red contra una lista negra (Malware/Virus) enviando una "Alerta de Emergencia".
- **Módulo de Automatización Forense:** Al detectar una amenaza, consulta vía API (AbuseIPDB/Whois) obteniendo datos de contacto del ISP para reportes de abuso.

Flujo del Sistema:

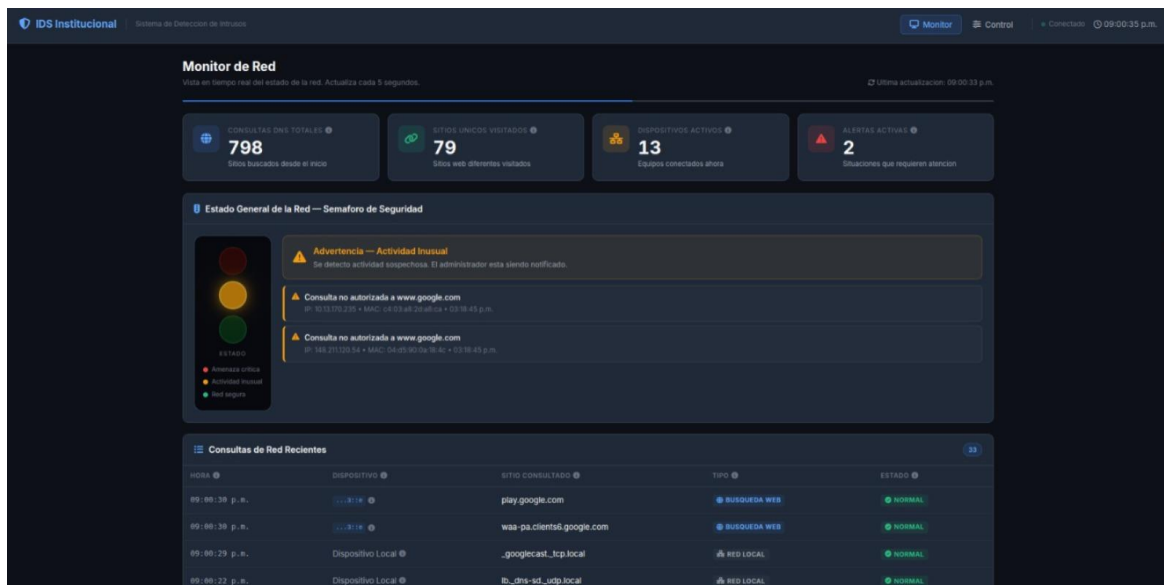


Figura 1. Dashboard Monitor de Red — Sistema IDS Institucional en funcionamiento. Se observan 798 consultas DNS registradas, 13 dispositivos activos y 2 alertas de actividad inusual detectadas en tiempo real.

2.2 Protección de Credenciales

Para evitar vulnerabilidades de contraseñas *hardcoded*, se implementaron variables de entorno mediante `python-dotenv`. El archivo `.env` contiene las credenciales del servidor de correo y claves API, y está excluido del control de versiones mediante `.gitignore`. Además, el envío de correos utiliza `server.starttls()` para cifrar la conexión SMTP y mitigar ataques *Man-in-the-Middle*.

2.3 Análisis Jurídico del Monitoreo y Política de Uso

El despliegue de este IDS está regulado por las siguientes leyes mexicanas vigentes:

1. Ley Federal de Telecomunicaciones y Radiodifusión (LFTR) — DOF 2014

El Artículo 189 establece que las instituciones están obligadas a implementar medidas de seguridad para proteger la integridad de sus redes. Esto ampara jurídicamente el monitoreo de la infraestructura propia.

2. Código Penal Federal — Artículo 211 bis 1

Tipifica como delito el acceso no autorizado a sistemas informáticos. El IDS actúa como herramienta defensiva de detección, plenamente justificada dentro de la red institucional.

3. LFPDPPP — DOF 2010

Las IPs y MACs almacenadas califican como datos personales bajo el Artículo 3 fracción V. Por tanto la institución debe cumplir:

- **Artículo 6** — Tratar datos de forma lícita y con finalidad legítima
- **Artículo 16** — Publicar Aviso de Privacidad informando el monitoreo
- **Artículo 19** — Adoptar medidas de seguridad para proteger los logs

Aviso de Privacidad Simplificado

La institución informa que los datos de tráfico de red (IPs, MACs y dominios consultados) son recopilados con la finalidad de garantizar la seguridad informática y detectar accesos no autorizados. Los datos serán conservados por un máximo de 90 días, accesibles solo por el administrador de red, y no serán compartidos con terceros salvo requerimiento de autoridad competente.

3. Conclusión

La implementación de este IDS Institucional demuestra cómo herramientas de bajo nivel como Scapy permiten una visibilidad granular del Modelo OSI. Automatizar la inteligencia de amenazas (mediante AbuseIPDB) y la gestión de alertas representa una reducción vital en los tiempos de respuesta ante incidentes.

En un entorno de producción real, el principal reto de seguridad radica en afinar las políticas de listas blancas y negras para evitar falsos positivos y mantener la eficiencia sin degradar el rendimiento de la red, siempre respetando los lineamientos de la LFPDPPP mexicana para el manejo ético de las bitácoras.

Edgar Alejandro Cedeño Suárez

El desarrollo de este Sistema IDS Institucional me permitió comprender de manera práctica cómo opera la seguridad de redes a nivel de paquetes. Trabajar con Scapy para capturar tráfico en tiempo real fue el mayor reto técnico, ya que requirió entender el modelo OSI no solo de forma teórica sino implementarlo directamente en código distinguiendo entre la capa de enlace para obtener MACs y la capa de red para las IPs.

Un reto de seguridad significativo fue el manejo de IPv6, protocolo que inicialmente no contemplamos y que dejaba al sniffer sin capturar tráfico moderno. Esto me enseñó que los sistemas de seguridad deben evolucionar constantemente ante nuevos protocolos y amenazas.

Respecto a la viabilidad en un entorno real, considero que este IDS es un punto de partida sólido para organizaciones pequeñas y medianas. Sin embargo, para producción requeriría procesamiento distribuido, almacenamiento escalable y un equipo dedicado a mantener actualizadas las listas negras. La integración con AbuseIPDB demostró el valor de la inteligencia de amenazas colaborativa — nadie puede monitorear internet solo.

René Rosendo De Anda Medina

La implementación del IDS Institucional demuestra el valor de integrar herramientas de bajo nivel como Scapy para obtener visibilidad granular del Modelo OSI, logrando inspeccionar el tráfico desde la capa de enlace hasta la capa de red. Retos como la integración de tráfico IPv6 destacaron la necesidad de crear sistemas de seguridad adaptables a protocolos emergentes. La automatización de la inteligencia de amenazas mediante AbuseIPDB y una gestión eficiente de alertas logran una reducción vital en los tiempos de respuesta ante incidentes.

Aunque el sistema es una excelente solución inicial para PyMEs, los entornos de producción reales exigen afinar constantemente las listas blancas y negras para evitar falsos positivos sin afectar el rendimiento de la red. A gran escala, este IDS requerirá procesamiento distribuido y un manejo ético de la información que cumpla estrictamente con la LFPDPPP. En suma, el proyecto es una prueba exitosa de cómo la seguridad a nivel de paquetes, combinada con inteligencia colaborativa, forma la primera línea de defensa moderna.

4. Bibliografía

- AbuseIPDB. (2026). *AbuseIPDB API v2 Documentation*. Recuperado de <https://docs.abuseipdb.com/>
- Anthropic. (2026). *Claude AI — Asistente de Inteligencia Artificial*. Recuperado de <https://claude.ai>
- Biondi, P. (2026). *Scapy Documentation*. Recuperado de <https://scapy.net/>
- Cámara de Diputados del H. Congreso de la Unión. (2014). *Ley Federal de Telecomunicaciones y Radiodifusión*. Diario Oficial de la Federación, México.
- Cámara de Diputados del H. Congreso de la Unión. (1999). *Código Penal Federal — Artículo 211 bis 1*. Diario Oficial de la Federación, México.
- INAI. (2010). *Ley Federal de Protección de Datos Personales en Posesión de los Particulares*. Diario Oficial de la Federación, México. Recuperado de <https://www.diputados.gob.mx/LeyesBiblio/pdf/LFPDPPP.pdf>
- ipwhois Project. (2026). *ipwhois Documentation*. Recuperado de <https://pypi.org/project/ipwhois/>
- Python Software Foundation. (2026). *python-dotenv Documentation*. Recuperado de <https://pypi.org/project/python-dotenv/>